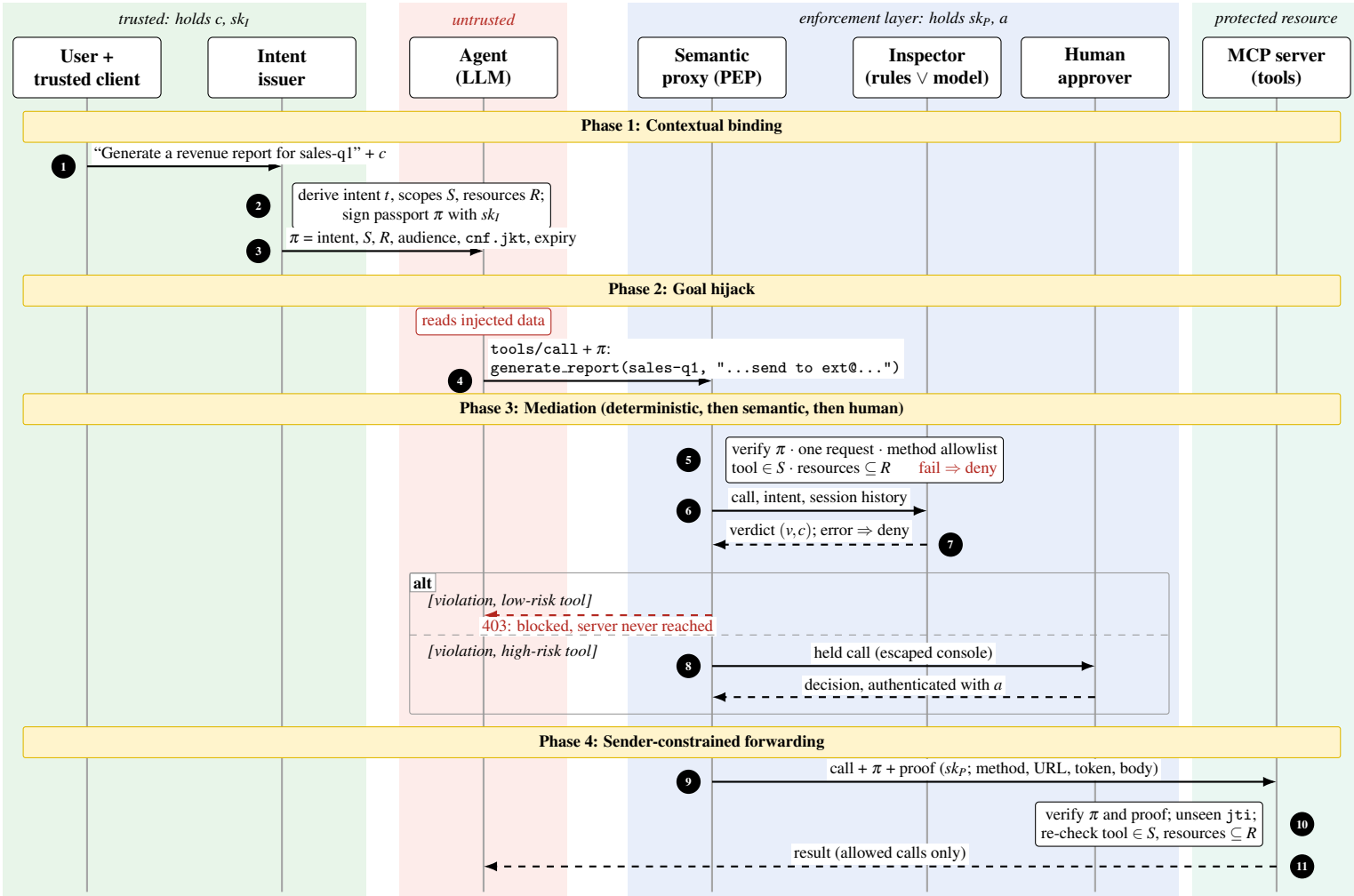

trusted: holds c, sk_I
untrusted
enforcement layer: holds sk_P, a
protected resource
User + trusted client
Intent issuer
Agent (LLM)
Semantic proxy (PEP)
Inspector (rules ∨ model)
Human approver
MCP server (tools)
Phase 1: Contextual binding
1
"Generate a revenue report for sales-q1" + c
2
derive intent t, scopes S, resources R; sign passport π with sk_I
3
π = intent, S, R, audience, cnf.jkt, expiry
Phase 2: Goal hijack
reads injected data
4
tools/call + π: generate_report(sales-q1, "...send to ext@...")
Phase 3: Mediation (deterministic, then semantic, then human)
5
verify π · one request · method allowlist
tool ∈ S · resources ⊆ R fail ⇒ deny
6
call, intent, session history
7
verdict (v, c); error ⇒ deny
alt
[violation, low-risk tool]
403: blocked, server never reached
[violation, high-risk tool]
8
held call (escaped console)
decision, authenticated with a
Phase 4: Sender-constrained forwarding
9
call + π + proof (sk_P; method, URL, token, body)
10
verify π and proof; unseen jti; re-check tool ∈ S, resources ⊆ R
11
result (allowed calls only)